Ticket 009 - Final Security Automation Engineering Report

Ticket #009 — Final Security Automation Engineering Report

Project: Identity Remediation Incident **Investigation Period:** October 11–18, 2026 **Environment:** Synthetic Identity-Remediation Laboratory **Engineering Status:** Laboratory Validation Completed **Production Status:** NOT APPROVED **Decision:** NO-GO for Full Unattended Destructive Remediation

---

1. Executive Summary

Ticket #009 investigated an identity-remediation automation incident involving the disabling of an account required by Finance LedgerBridge.

The original V1 automation relied primarily on interactive-login inactivity and did not adequately account for service-account usage, application dependencies, or authorization boundaries.

A synthetic laboratory reproduced the unsafe behavior and provided a controlled environment for engineering improvements.

Three automation generations were evaluated:

- V1: Original inactivity-based remediation.
- V2: Identity-aware decisions and execution safeguards.
- V3: Evidence corroboration, trust validation, and stronger failure handling.

The investigation included rollback testing, failure injection, idempotency validation, and adversarial testing.

The redesigned automation is substantially safer in the tested laboratory scenarios, but production-grade execution controls remain incomplete.

Final recommendation: Do not enable unattended destructive identity remediation in production.

2. Incident Overview

Known Incident Timeline

Time	Event
08:52	Identity-remediation automation executed
08:57	Finance Operations reported application failures
09:07	SOC assumed incident ownership
Subsequent investigation	IAM identified a disabled service account

Business Impact

The affected identity supported Finance LedgerBridge.

Disabling the identity interrupted an application dependency required for Finance Operations.

The original incident demonstrated that a single incorrect identity-state change can affect business services beyond the targeted account.

Initial Response Priorities

1. Suspend further destructive remediation.
2. Restore the affected identity and application service.
3. Preserve automation and identity evidence.
4. Determine the root cause.
5. Evaluate the automation's destructive authority.
6. Implement safer controls.
7. Validate the redesigned approach before production consideration.

3. Root-Cause Analysis

Immediate Cause

V1 disabled a service identity required by a business application.

Technical Cause

The automation used an interactive inactivity threshold without sufficient consideration of noninteractive authentication and service dependencies.

Systemic Cause

The authorization model allowed an incomplete identity signal to trigger destructive remediation.

The system did not sufficiently establish:

- Accurate identity classification
- Legitimate business purpose
- Noninteractive account activity
- Application dependencies
- Ownership and criticality
- Reliable evidence
- Appropriate approval authority

Root-Cause Conclusion

The failure was not merely an incorrect threshold.

It was the combination of insufficient evidence and excessive destructive authority.

4. Laboratory Design

The laboratory used synthetic identity records, Python automation, JSON working copies, CSV decision records, and structured logs.

The original dataset contained ten synthetic identities.

V3 expanded the dataset to eleven identities, including payroll.emergency.

The environment enabled reproducible testing without modifying production identities.

Primary Components

- Synthetic IAM identity inventory
- Secondary application and lifecycle context
- V1, V2, and V3 decision implementations
- Isolated remediation execution tests
- Rollback and recovery scripts
- Failure-injection scenarios
- Adversarial automation tests
- Audit and decision evidence

Scope Limitation

This was a laboratory investigation.

No production IAM platform integration or production destructive execution is claimed.

5. V1 Engineering Assessment

Original Logic

V1 primarily evaluated interactive-login inactivity using a 90-day threshold.

Observed Behavior

The simulation reproduced an unsafe disable affecting a business dependency.

Major Weaknesses

- Inactivity confused with lack of business use
- Inadequate service-account handling
- Insufficient dependency verification
- Overly broad destructive authority
- Inadequate approval boundaries

V1 Assessment

FAIL — Unsafe for unattended destructive remediation.

The original failed behavior was preserved as evidence.

6. V2 Engineering Improvements

V2 introduced stronger decision and execution controls.

Design Improvements

- Identity-aware context evaluation
- Confidence classification
- Automation authority classification
- Human-approval boundaries
- Protected identity handling
- Execution limits
- Dry-run decisions
- Deferred operations
- Structured execution evidence
- Rollback capability
- Emergency-stop testing

Testing

V2 testing covered malformed inputs, repeated runs, logging failures, emergency-stop behavior, enforcement, and rollback.

An initial cross-run idempotency weakness was preserved and corrected.

V2 Assessment

V2 improved the safety of remediation execution.

However, safer execution did not establish that all supporting identity evidence was trustworthy.

7. V3 Engineering Improvements

V3 introduced explicit evaluation of evidence trust in addition to decision confidence.

Evidence Trust Model

The engine evaluates:

1. Primary identity information
2. Secondary identity context
3. Evidence completeness
4. Conflicting information
5. Source integrity
6. Observation freshness
7. Appropriate automation authority

Authority Categories

Classification	Meaning
AUTO_REMEDIATE	Meets bounded laboratory automatic-authority criteria
REQUIRE_APPROVAL	Human authorization or further investigation required
DO_NOT_AUTOMATE	Automated remediation is prohibited

An AUTO_REMEDIATE classification is not production execution authorization.

Canonical V3 remains dry-run only.

Payroll Conflict Scenario

The payroll.emergency primary record suggested an inactive standard employee.

Secondary context indicated an active critical payroll integration.

The historical V3 result was:

- Decision confidence: HIGH
- Evidence trust: CONFLICTING
- Recommendation: DISABLE
- Authority: REQUIRE_APPROVAL
- Actual action: NO_ACTION_DRY_RUN

This showed that high decision confidence does not override contradictory business evidence.

8. V3 Failure-Injection Testing

Ten failure-injection scenarios were documented.

Test	Scenario	Validated Outcome
F01	Missing primary evidence	Authority reduced after correction
F02	Corrupted input	Structured fail-closed handling after correction
F03	Logging unavailable	Audit preflight prevents unsafe processing
F04	Duplicate execution	Already-completed action not repeated
F05	Interrupted execution	Safe recovery and restart behavior
F06	Failed remediation	Failure recorded and prior state preserved
F07	Failed rollback	Manual recovery escalation required
F08	Approval timeout	Expired pending request blocked
F09	Unsupported identity type	DO_NOT_AUTOMATE
F10	Missing secondary context	REQUIRE_APPROVAL

Important Findings

F01 through F03 exposed weaknesses that were preserved before corrective changes.

F04 through F10 tested operational safeguards using isolated laboratory scenarios.

Failure-Injection Assessment

The tested corrections and safeguards produced the documented expected results.

These laboratory tests do not establish fully integrated production enforcement.

9. Adversarial Automation Testing

Three adversarial scenarios challenged the automation's trust boundaries.

A01 — Secondary Evidence Poisoning

An altered secondary source initially produced:

- HIGH confidence
- TRUSTED evidence
- AUTO_REMEDIATE authority

Correction:

Validate source integrity against a protected SHA256 baseline before decision generation.

Corrective result:

- FAIL_CLOSED
- SECONDARY_SOURCE_INTEGRITY_FAILURE
- Zero decision records
- No remediation performed

A02 — Freshness Metadata Forgery

Stale evidence dated January 1, 2025 was labeled current.

Initially, V3 incorrectly granted TRUSTED evidence and AUTO_REMEDIATE authority.

Correction:

Independently validate observation timestamps and calculate evidence age.

Maximum accepted age for trusted unattended authority: 24 hours.

Corrective result:

- Evidence trust: STALE
- Authority: REQUIRE_APPROVAL
- Actual action: NO_ACTION_DRY_RUN

A03 — Approval Forgery and Replay

An unverified APPROVED value initially permitted synthetic remediation.

The same generic approval reference was successfully reused after restoring the test identity state.

An isolated corrective workflow introduced:

- Signed approval artifacts
- Unique approval identifiers
- Target and action binding
- Authorized approver validation
- Expiration checking
- One-time-use approval consumption
- Fail-closed behavior when verification controls are unavailable

Corrective tests blocked replay, signature tampering, identity mismatch, action mismatch, expired approvals, missing keys, and unavailable ledgers.

Adversarial Assessment

All three original trust-boundary failures were reproduced and documented.

Corrective testing passed for the tested scenarios.

A03 authorization controls remain isolated from canonical V3 enforcement and are not production-ready.

10. Rollback, Recovery, and Idempotency

The laboratory evaluated:

- Prechange identity snapshots
- Identity-state restoration
- Duplicate operations
- Interrupted execution
- Failed remediation
- Failed rollback
- Approval timeout

Key Finding

A recovery procedure is not sufficient merely because restoration is theoretically possible.

The F07 failure-injection scenario demonstrated that rollback can fail and require manual escalation.

Recovery Requirement

Production recovery must verify both identity-state restoration and dependent application health.

11. Automation Authority and Least Privilege

Automation authority must be separated across functions.

Required Separation

- Evidence collection
- Decision evaluation
- Approval issuance
- Approval verification
- Remediation execution
- Audit logging
- Emergency recovery

The remediation executor must not be able to approve its own operations or modify protected evidence and audit records.

Production Gap

Least-privilege permissions have been designed but not independently enforced and tested on a production IAM platform.

12. IAM Allowlist Recommendation

An unrestricted permanent allowlist is not recommended.

Although permanent exclusions might protect known critical accounts, they can conceal inaccurate identity records and allow unnecessary access to remain indefinitely.

A safer approach is a narrowly scoped exception process with:

- Verified ownership
- Documented business justification
- IAM approval
- Application-owner confirmation
- Scheduled review
- Expiration
- Continued monitoring

The exception must restrict destructive automation without removing the account from security oversight.

13. Operations and Drift

Operations Plan

The operations plan defines:

- Pre-execution checks
- Evidence integrity and freshness verification
- Approval procedures
- Monitoring schedules
- Emergency-stop conditions
- Recovery and restart requirements
- Change management
- Production readiness criteria

Current Evidence Drift

Canonical secondary evidence includes observations dated October 16, 2026.

As of October 18, these observations exceed V3's 24-hour freshness threshold.

Historical TRUSTED and AUTO_REMEDIATE classifications must therefore not be treated as current authorization.

Fresh evidence must be collected from authoritative sources.

Timestamps must not be artificially advanced to manufacture freshness.

Drift Assessment

Automation safety must be reevaluated as evidence, dependencies, rules, and permissions change.

A successful historical test does not establish permanent safety.

14. Before/After Engineering Assessment

Dimension	V1	V2	V3
Decision basis	Interactive inactivity	Identity context	Corroborated identity evidence
Evidence trust	Limited	Improved context	Integrity and freshness validation
Approval boundaries	Inadequate	Introduced	Isolated signed approval testing
Execution safety	Unsafe disable reproduced	Bounded safeguards	Canonical dry-run only
Recovery	Reactive	Tested rollback	Additional failure injection
Operator visibility	Limited	Structured results	Confidence, trust, authority, and action
Production readiness	Unsafe	Not approved	Not approved

Engineering Conclusion

V1 prioritized action without adequate context.

V2 improved execution safeguards.

V3 improved evidence-trust assessment and demonstrated additional authorization controls in isolated testing.

15. Remaining Production Risks

The following gaps remain:

1. Canonical V3 does not implement production destructive execution.
2. A03 approval controls are not integrated into one protected enforcement service.
3. Production identity permissions remain unvalidated.
4. Approval signing and consumption require independently protected infrastructure.
5. Audit logging requires tamper-resistant production storage.
6. Evidence sources require authoritative refresh.
7. Integrity baseline changes require independent approval.
8. Emergency-stop and rollback safeguards require integrated production testing.
9. Production operational thresholds have not been validated.
10. Formal production change authorization has not been granted.

16. Production Readiness Assessment

Area	Current Status
Incident reproduction	Completed in laboratory
Root-cause investigation	Documented

Area	Current Status
V2 decision and safety testing	Completed in laboratory
V3 evidence validation	Tested
F01–F10 failure injection	Documented and validated
A01–A03 adversarial testing	Corrective tests passed
Independent production approval service	Not implemented
Production least-privilege enforcement	Not validated
Integrated production recovery	Not validated
Formal production approval	Not granted

Production Decision

NO-GO — Full unattended destructive remediation.

17. Recommended Next Actions

Immediate

- Keep unattended destructive remediation disabled.
- Continue read-only evidence collection.
- Run dry-run decisions.
- Review conflicting or stale evidence.
- Preserve audit and validation evidence.

Before Limited Destructive Automation

- Integrate independently authenticated approval enforcement.
- Implement protected one-time-use authorization.
- Enforce production least privilege.
- Validate authoritative evidence refresh.
- Test audit logging, emergency stop, and rollback together.
- Perform independent security review.
- Obtain formal change approval.

Ongoing

- Monitor evidence quality and drift.
- Review exceptions and ownership.
- Track remediation recommendations and false positives.
- Periodically retest failure and adversarial scenarios.
- Maintain tested recovery procedures.

18. Supporting Evidence and Deliverables

Incident Records

- incident/incident-response-record.md
- incident/incident-timeline.md
- incident/containment-and-recovery-record.md

Engineering Analysis

- environment/identity-environment-design.md
- environment/identity-context-analysis.md
- incident/root-cause-analysis.md
- design/iam-manager-response.md
- security/automation-authority-matrix.md
- security/safeguard-register.md
- security/failure-mode-register.md
- operations/automation-change-record.md

Automation Implementations

- automation/v1-remediator.py
- automation/v2-decision-engine.py
- automation/v2-enforcer.py
- automation/v2-rollback.py
- automation/v3-decision-engine.py
- automation/v3-rollback.py

Validation Evidence

- evidence/v1-decisions.csv
- evidence/v1-remediation.log
- evidence/v3-dry-run-decisions.csv
- tests/v3-failure-injection-results.md
- tests/v3-adversarial-test-results.md
- tests/v3-rollback-validation.md

Final Engineering Records

- engineering-notebook.md
- lessons-learned.md
- operations/automation-operations-plan.md
- operations/automation-drift.md
- management/security-automation-decision-brief.md

19. Final Engineering Conclusion

Ticket #009 demonstrated that automated identity remediation can create serious business impact when destructive authority is based on insufficient evidence.

The original V1 failure was reproduced using synthetic identities.

V2 introduced stronger identity-aware authority and execution controls.

V3 introduced evidence corroboration, integrity verification, freshness validation, and additional adversarial testing.

The engineering work demonstrated meaningful improvements while identifying important remaining production control gaps.

Final recommendation: Continue advisory and dry-run automation. Do not authorize full unattended destructive production remediation.

This report documents engineering validation and recommendations. It does not claim production deployment or formal production approval.